Lattice (PQC) Cryptography Challenges

Trill White

CYBERCON 2026
AUSTRALIAN CYBER CONFERENCE

This talk will cover:

- What is PQC?
- Why are we worried?
- What can we do?
- What are we doing?
- Current challenges with PQC?
- What next?
- A bit about the global scene

This talk will not cover:

- How great it wouldbe to combine Quantum with AI
- When we get Qu|antum Computers
- It is gonna create black holes

This is designed for...

- Managerswho wantabroad understanding of what’s going on with this buzzword
- Students
- Deep dive for Security Analysts / Threat Hunters

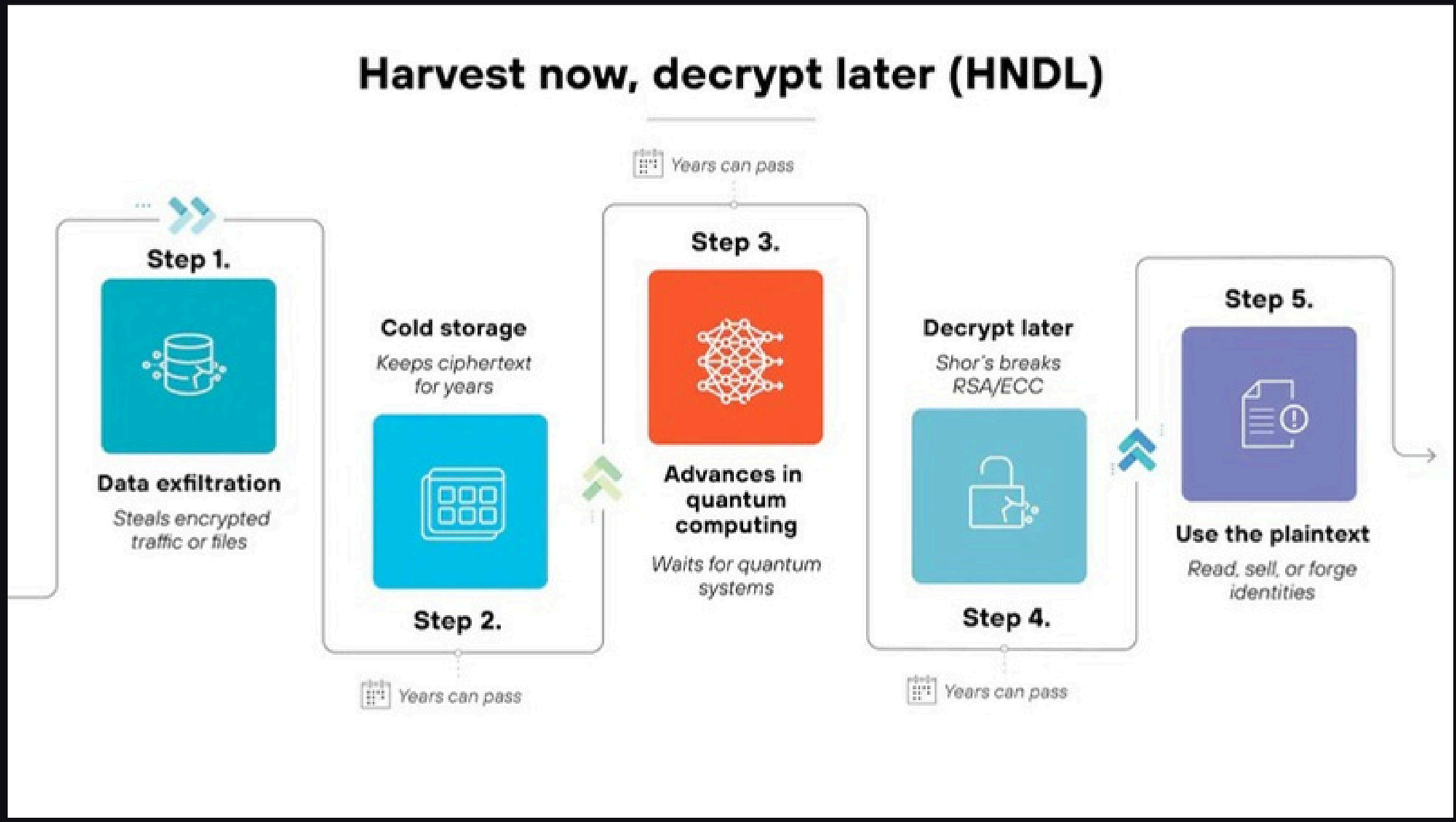
PQC

- Post Quantum Cryptography
- If we ever get quantum computers, goodbye modern encryption (Shors algorithm) How
- can we build schemes that are going to protect against this?

Okay, so its a future problem?

lol, no....

HNDL


Harvest now, decrypt later (HNDL)
Step 1.
Data exfiltration
Steals encrypted traffic or files
Cold storage
Keeps ciphertext for years
Step 2.
Years can pass
Years can pass
Step 3.
Advances in quantum computing
Waits for quantum systems
Decrypt later
Shor's breaks RSA/ECC
Step 4.
Years can pass
Step 5.
Use the plaintext
Read, sell, or forge identities

Okay, so its a ~~now~~ problem...

PQC in a nutshell

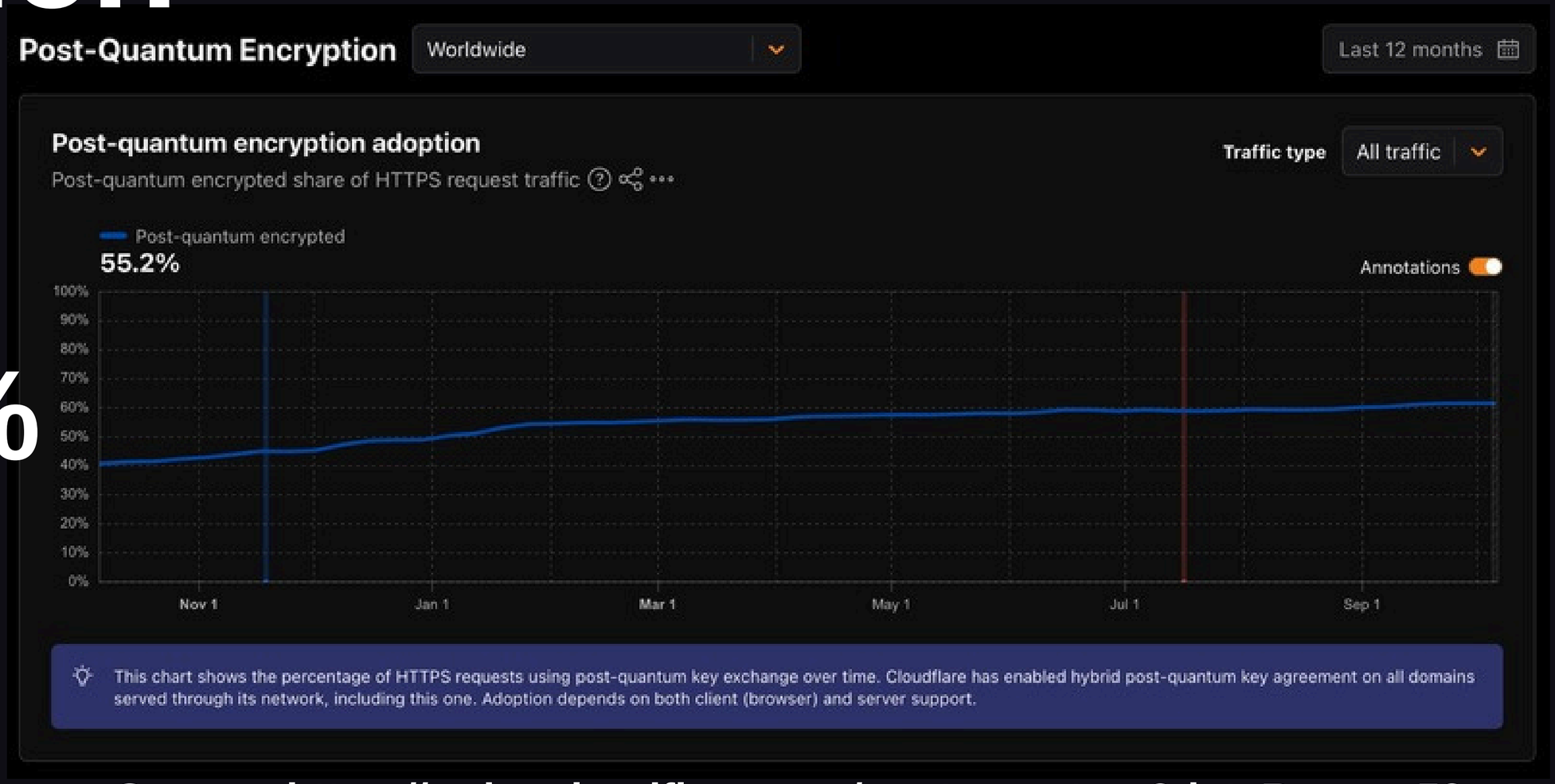
- Post Quantum Cryptography is anew encryption type
- Key standards: ML-KEM (Key Exchange) & ML-DSA (Signatures)
- Quantum-Resistant: Protects against both classical and quantum attacks

ML-KEM FIPS 203

- ML-KEM (formerly CRYSTALS-Kyber), finalised by NIST in August 2024
- NIST Approved in August 2024
- already deployed in Google Chrome, Cloudflare, and Apple PQ3
- Built on Module Learning With Errors (M-LWE)

Then

55%



Source: https://radar.cloudflare.com/post-quantum?dateRange=52w

Now

72%

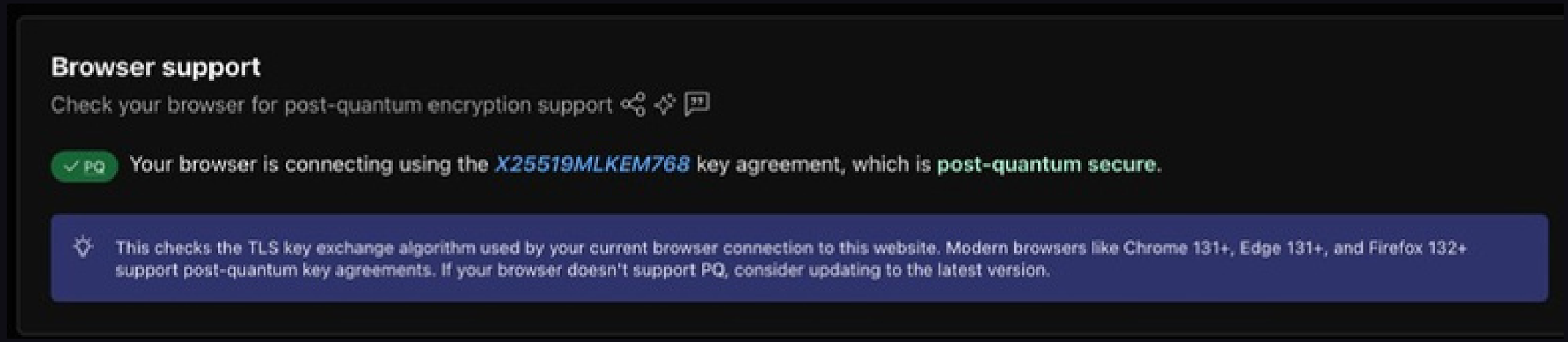


CYBERCON 2026
AUSTRALIAN CYBER CONFERENCE

Source: https://radar.cloudflare.com/post-quantum?dateRange=52w

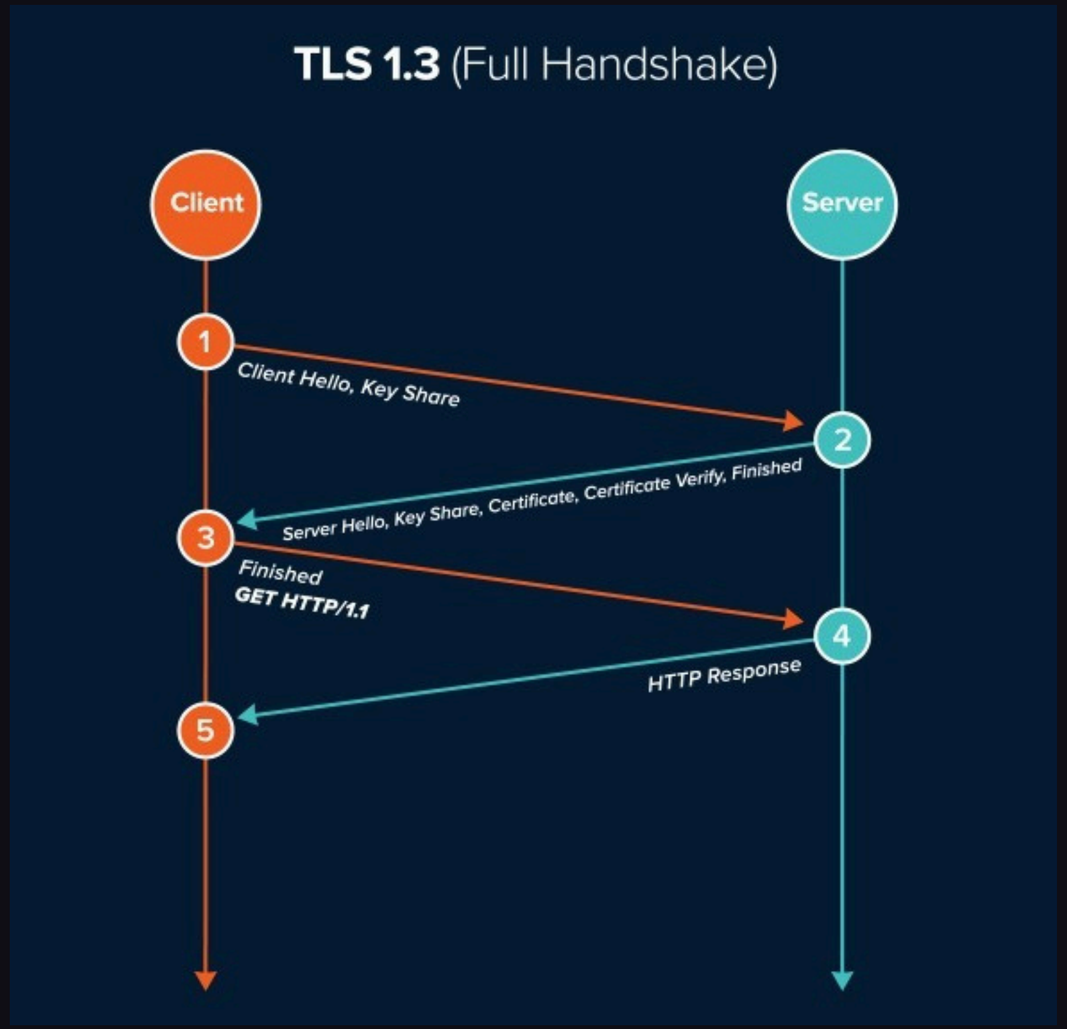
Your browser

For example



TLS Handshake

- TLS is where encryption begins...
- Classical is ECC (X25519)
- Post-Quantum is (ML-KEM-768)



TLS Future

- TLS 1.1 depricated
- TLS 1.2 upgrade to TLS 1.3
- TLS 1.3 is the required baseline for PQC hybrid key exchanges
- TLS is already 90% of all TLS used on the internet

So crisis averted?

Well, no ....

So crisis averted?

- ML-KEM tells us the connection is secure ...
- ... it doesn’t tell us who is on the other side of this connection!

so...

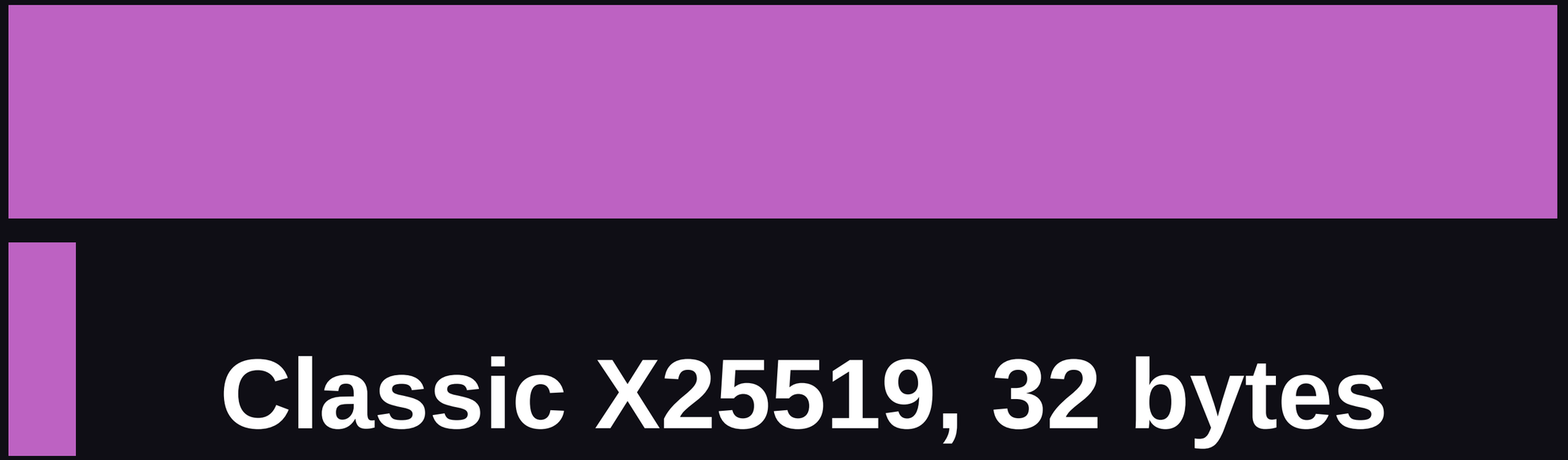
Challenges

- Packet Size / certificates of authority
- cost in data storage and sending
- server uptake
- Different standards + timelines
- Backwards compatibility
- Downgrade attacks

Packet Size

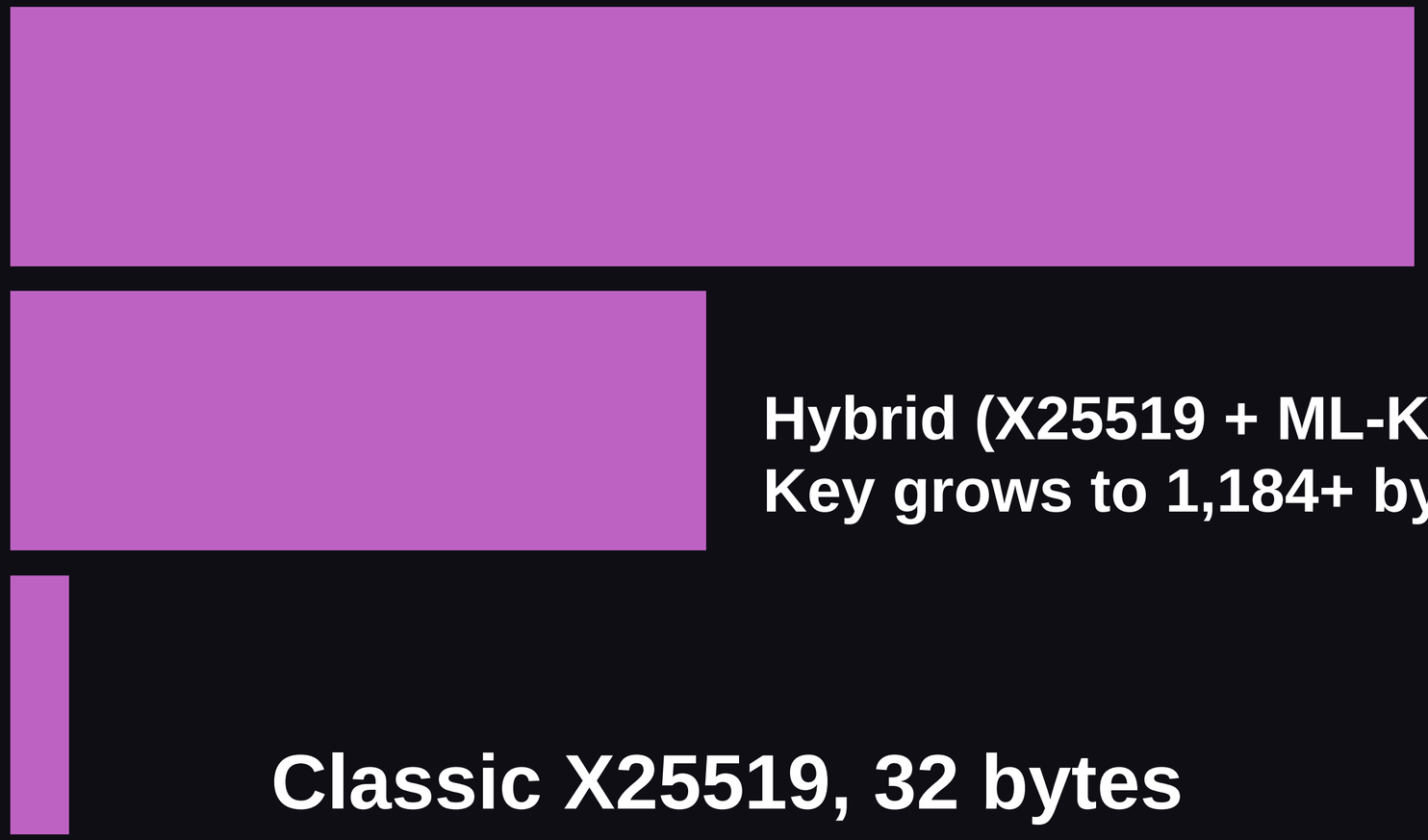
Packet Size Overhead

Hybrid (X25519 + ML-KEM-768) 35x larger
Key grows to 1,184+ bytes



Classic X25519, 32 bytes

Certificates cost even more



ML-DSA (FIPS 204)
Adds 4,000 - 6,000 bytes

Hybrid (X25519 + ML-KEM-768) 35x larger
Key grows to 1,184+ bytes

Classic X25519, 32 bytes

Solution?

- Post-quantum signatures (ML-DSA) expand certificate chains by up to 40x
- Cloudflare / Other researchers suggest Merkle Trees Certificates
- Certificate verification proofs jumps down to a few hundred bytes.
- Now back to single-packet handshakes, avoiding packet fragmentation and middlebox drops

Sheer Cost ($)

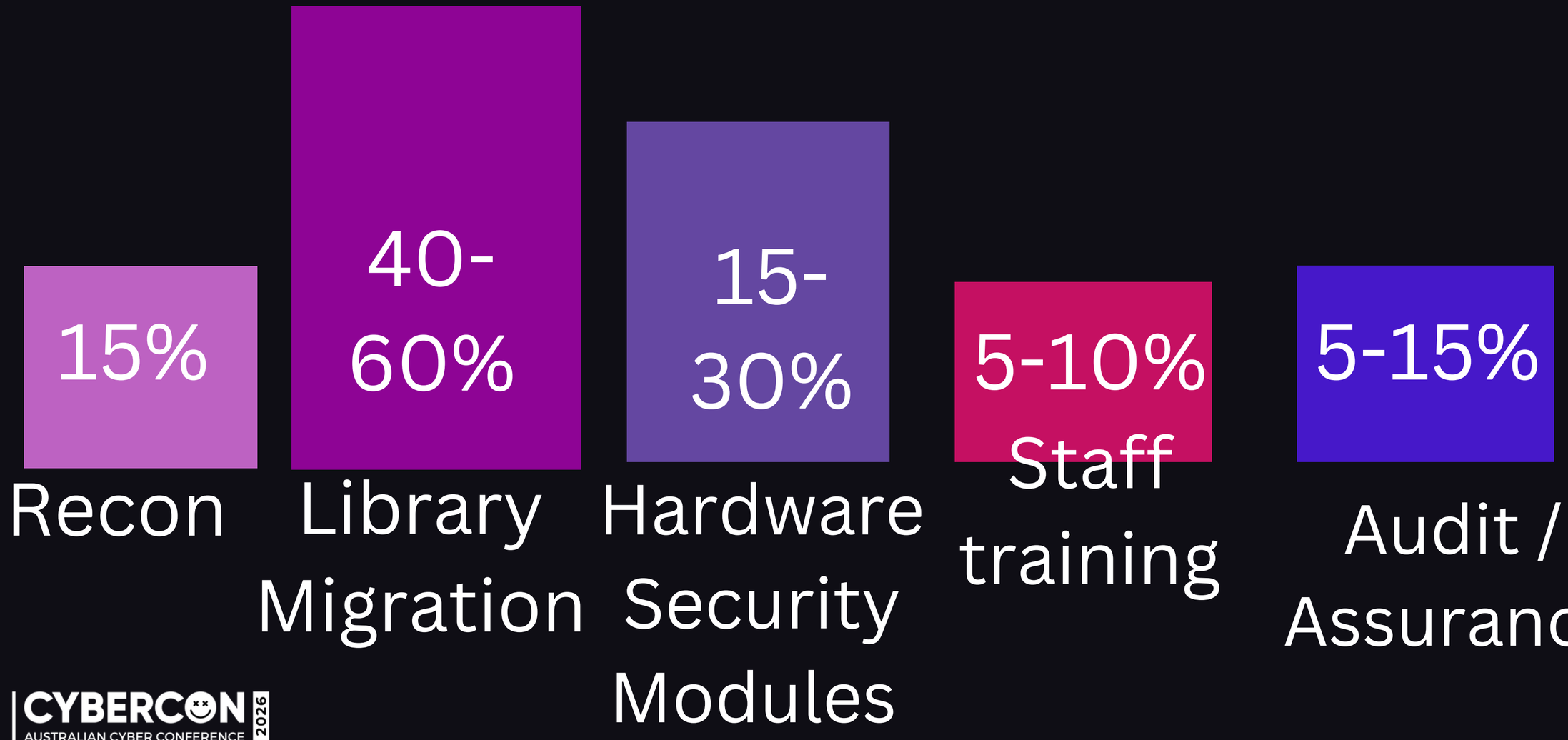
Server uptake



Some rough numbers

- Quantum Security Defenseisaglobal organisationthat helpseducation,promoteand advance quantum technologies
- They estimate:
- $10k–$500k for SMBs, $5M–$15M+ for large enterprises
- SMBs mostly rely on services like AWS
- Breakdown on next page...

src:https://quantumsecuritydefence.com/insights/pqc-migration-cost-benchmarks-enterprise/



Different standards

NIST Is Important

- AstheU.S. National Institute of Standards and Technology, its FIPS (Federal Information Processing Standards) set the baseline for federal agencies and tech vendors worldwide

Once upon a NIST ....



"Where oh where is PQC?" - 2016

Once upon a NIST ....



CRYSTALS
-KYBER



KRYSTALS-
DILITHIUM



SPHINCS+



FALCON



CYBERCON 2026
AUSTRALIAN CYBER CONFERENCE

Once upon a NIST ....

82 over 5 years were proposed....



FIPS 203



FIPS 204

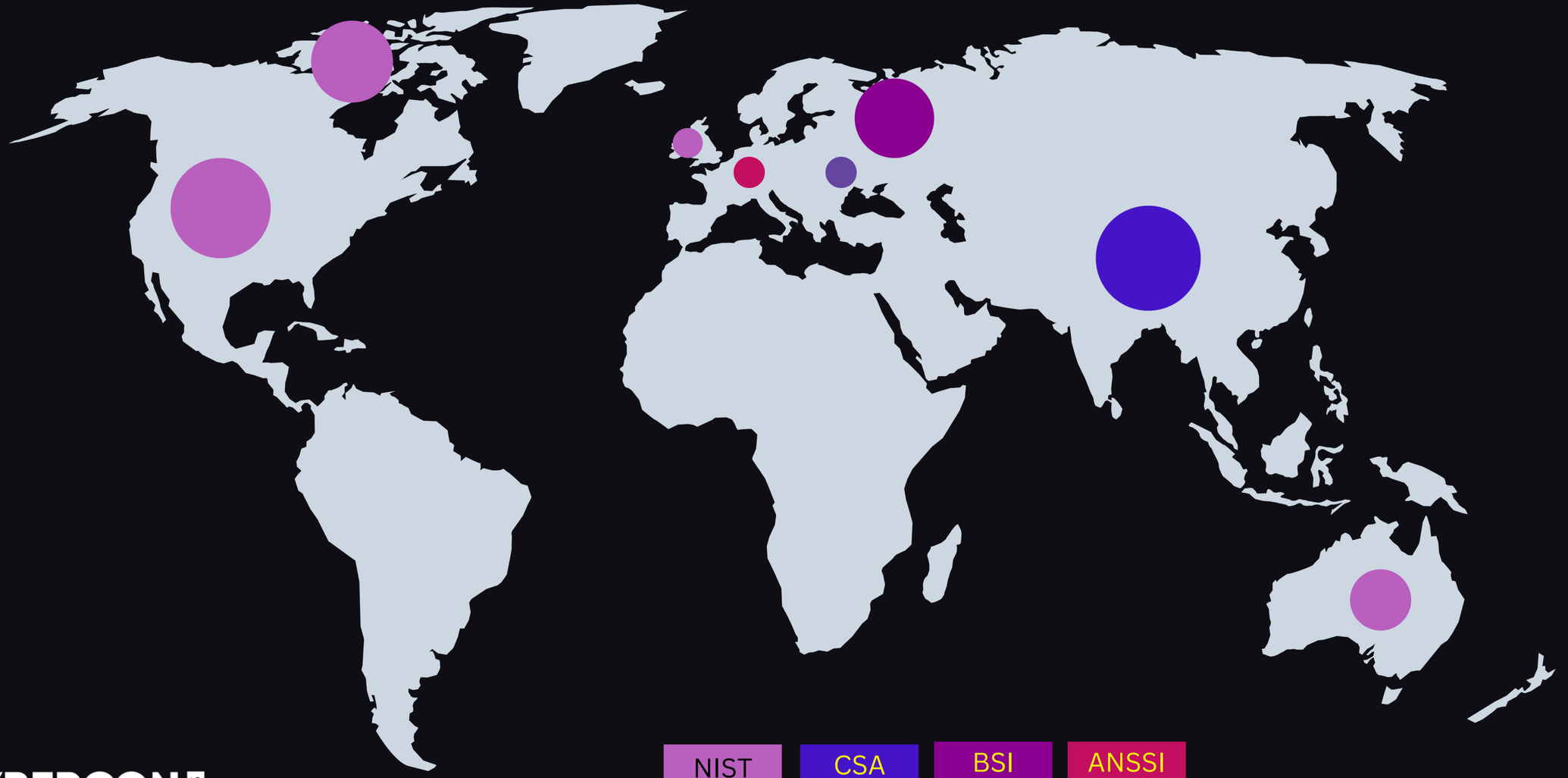


FIPS205

FIPS206



Standard Bodies



Redundancy is Good

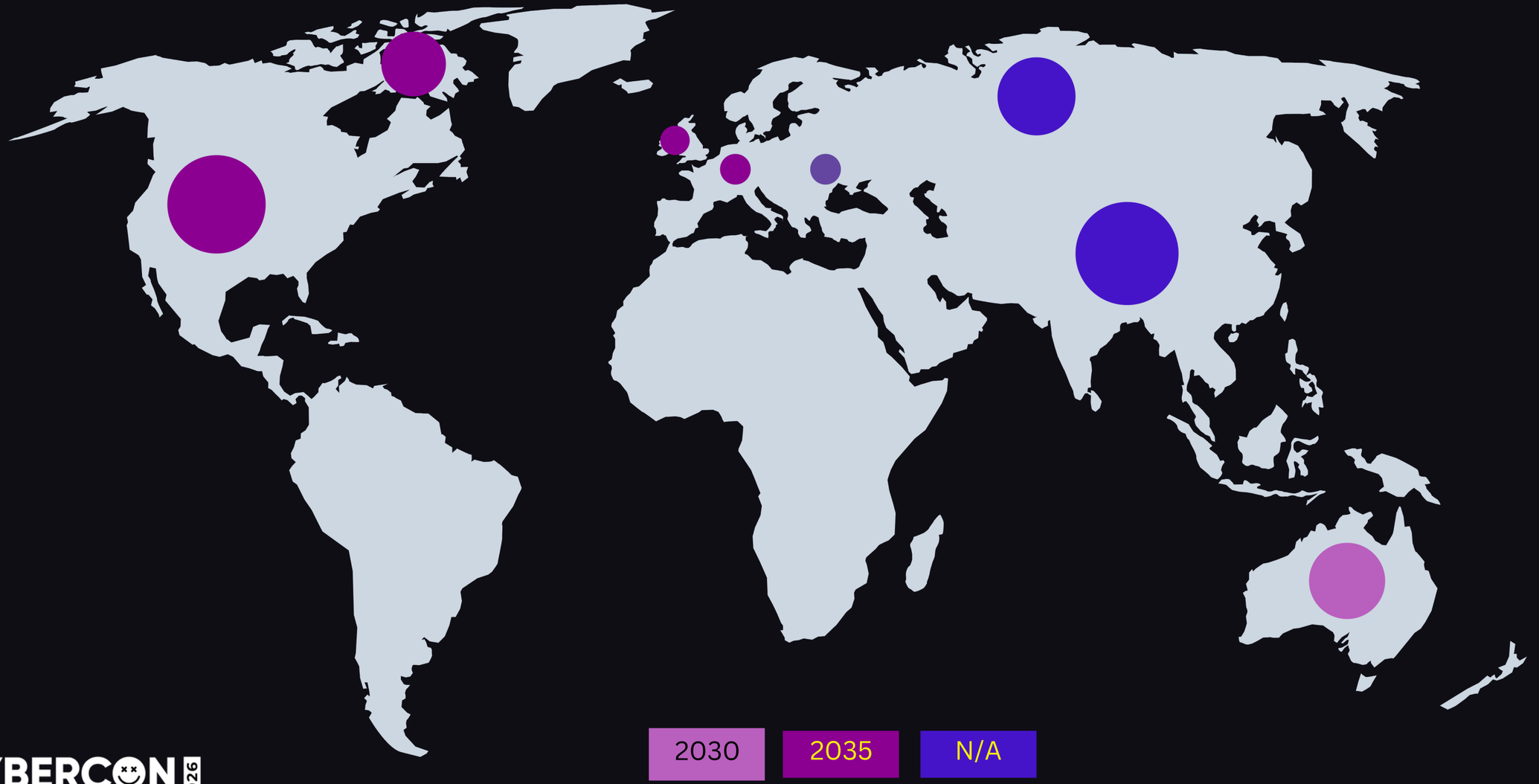
- More than one scheme meansmorethanone option for the future
- Not all eggs are in the one basket

Redundancy is Bad

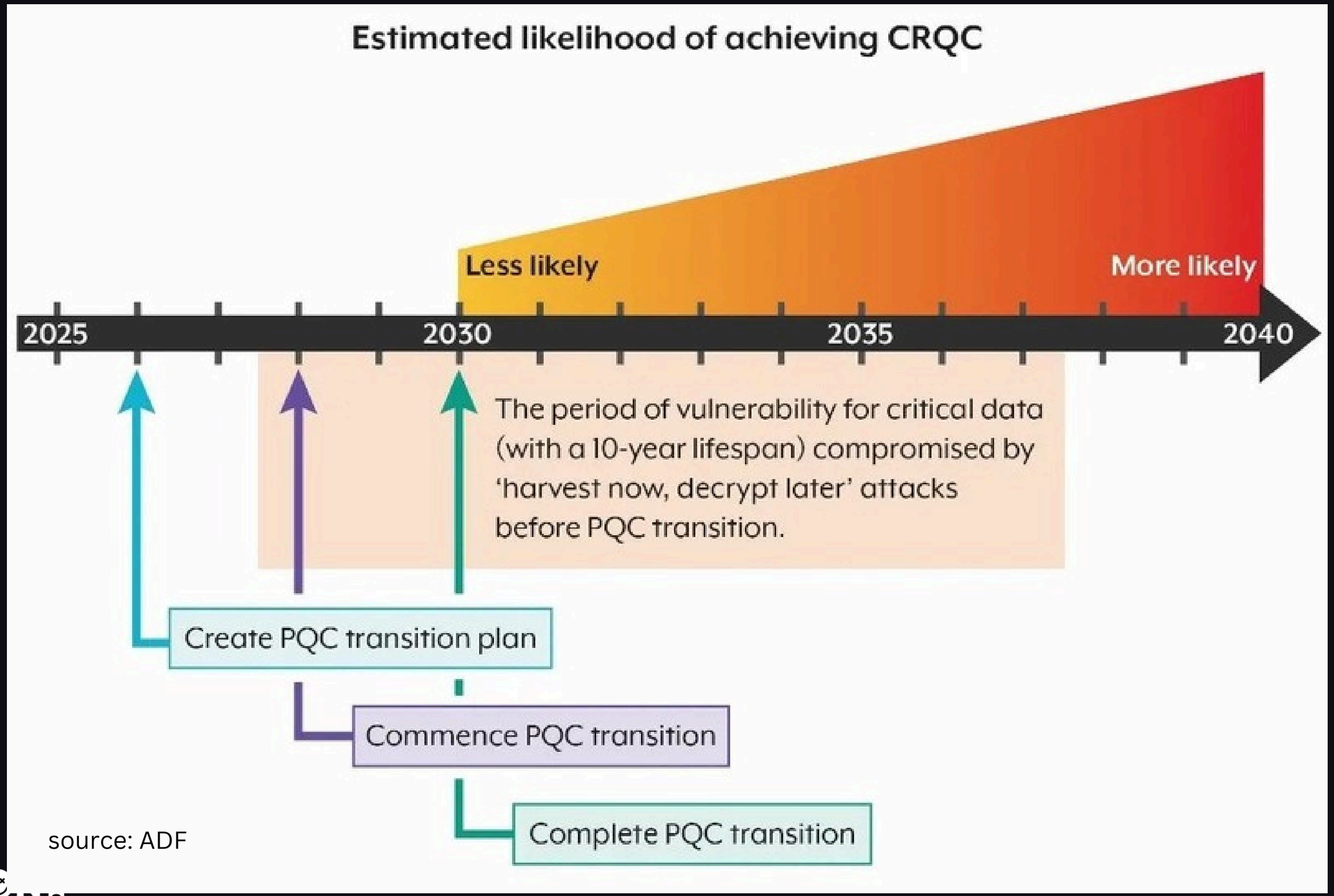
- Now servers needto beabletocommunicate in more thanone PQC scheme
- Edge servers (country-to-country) need to know a LOT of PQC schemes to be able to “translate” between them

Different timelines

Timelines



Australia’s Timeline


Estimated likelihood of achieving CRQC
Less likely
More likely
2025
2030
2035
2040
The period of vulnerability for critical data (with a 10-year lifespan) compromised by 'harvest now, decrypt later' attacks before PQC transition.
Create PQC transition plan
Commence PQC transition
Complete PQC transition

source: ADF

Current global policy

- Key Exchange (KEM):Production Ready(ML-KEM deployed via Cloudflare/Browsers).
- Authentication (Signatures): Work in progress with Cloudflare and other groups testing
- Public PKI Trust: Also in progress internationally

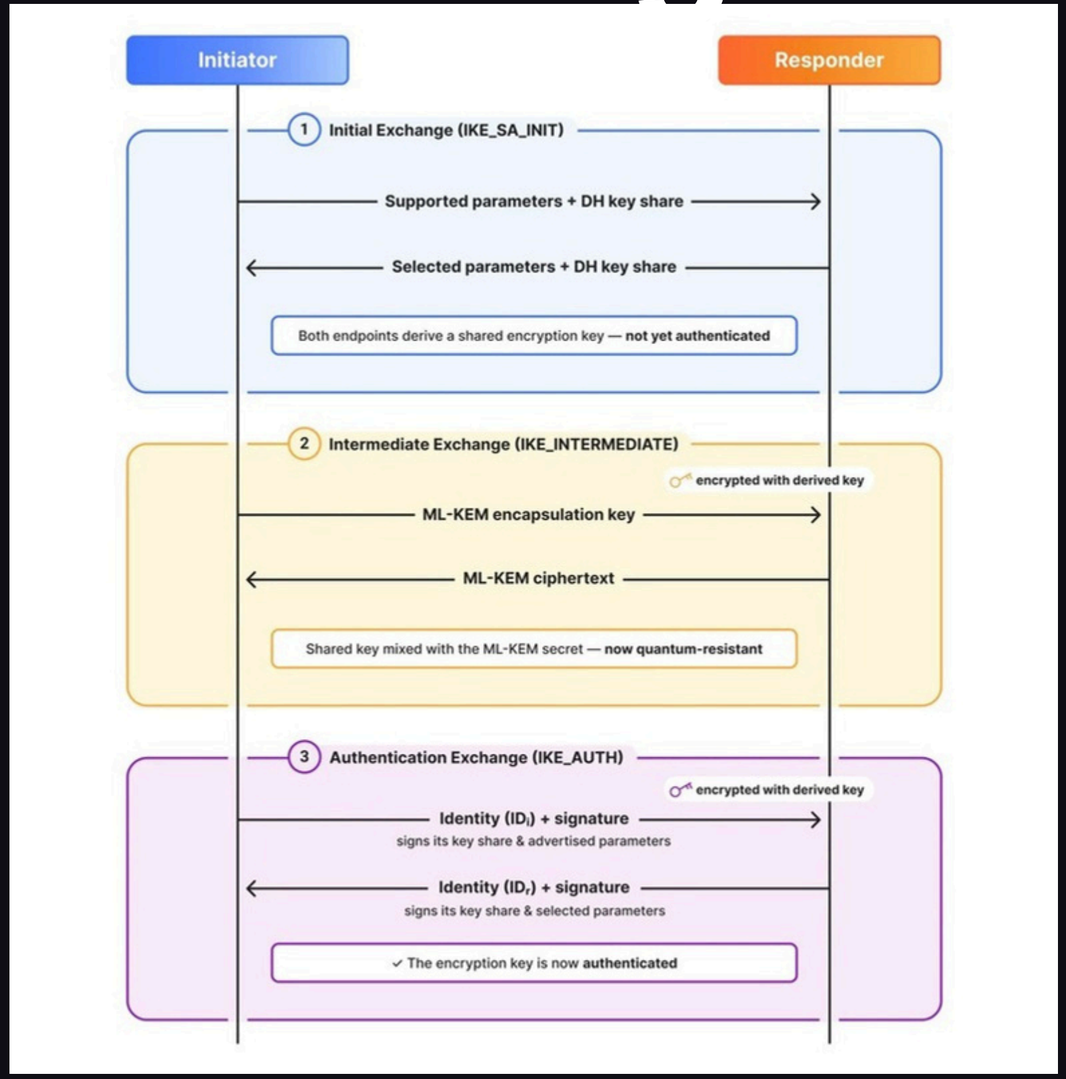
Backwards Compatibility

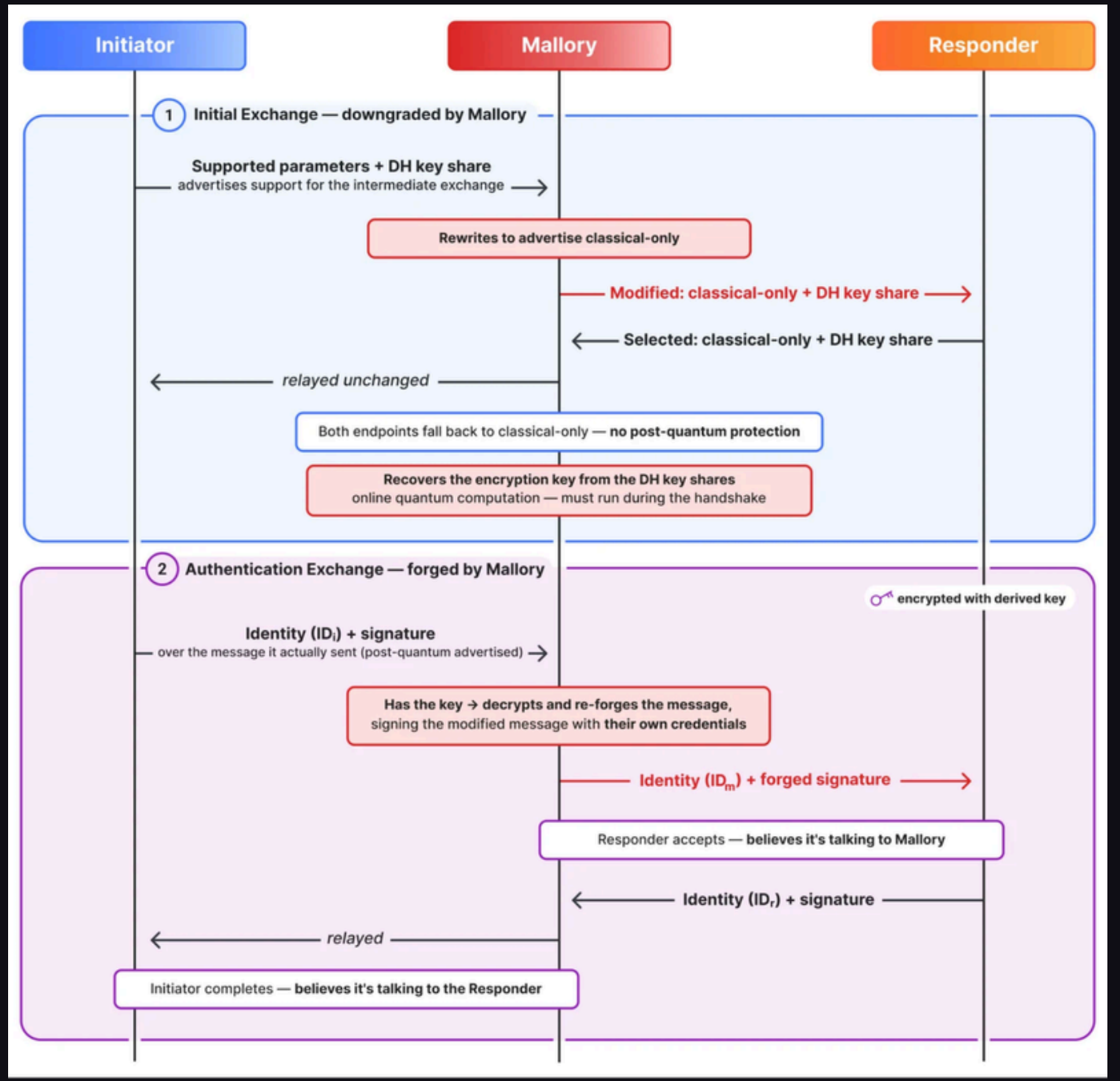
Needed because:

- Phased Transition: Asynchronousadoption means multi-year backward compatibility.
- High migration costs, legacy infrastructure, and complex asset dependencies.
- Regulatory Alignment is Australian Government 2025–2030 Roadmap requiring hybrid key exchange during the transition window.

Downgrade Attacks

Threat: Downgrades




Initiator
Mallory
Responder
1 Initial Exchange — downgraded by Mallory
Supported parameters + DH key share
advertises support for the intermediate exchange
Rewrites to advertise classical-only
Modified: classical-only + DH key share
Selected: classical-only + DH key share
relayed unchanged
Both endpoints fall back to classical-only — no post-quantum protection
Recovers the encryption key from the DH key shares
online quantum computation — must run during the handshake
2 Authentication Exchange — forged by Mallory
encrypted with derived key
Identity (ID$_i$) + signature
over the message it actually sent (post-quantum advertised)
Has the key → decrypts and re-forges the message,
signing the modified message with their own credentials
Identity (ID$_m$) + forged signature
Responder accepts — believes it's talking to Mallory
Identity (ID$_r$) + signature
relayed
Initiator completes — believes it's talking to the Responder

Solutions?

Protections

- Upgrading TLS 1.2to 1.3
- TLS1.3 offers Transcript Binding
- During the handshake, both the client and server keep a running hash of every single byte exchanged. At the end, they verify this transcript.

Summary

- Heading towards TLS 1.3
- Merkle TreeCertificates fix a bunch!
- This is a gradual process over the next 5 years for Australia
- There is likely going to be some CAs that emerge to allow all this

Closing Thoughts

- **Thiswas a brief run down**
- **Meant to be survivable**
- **Hasn’t touched on everything**
- **Thanks for listening!!**



Contact

Trill White
LinkedIn: Trill White
Email: trill.white@deakin.edu.au

CYBERCON 2026
AUSTRALIAN CYBER CONFERENCE